LedgerHouse HMRC Plain-English Guide

Date prepared: 2026-07-13

Software: LedgerHouse / KAFS UK Accounting SaaS

What This Document Is For

This is the plain-English explanation of the work done before requesting HMRC production credentials.

It is written so a non-technical person can understand what was checked, why it mattered, and why the HMRC request was submitted.

What LedgerHouse Is

LedgerHouse is intended to work like a full accounts department for a client business.

The client uses the portal to upload invoices, receipts, bank files, spreadsheets, PDFs, photos and other business records. The accountant or accountancy practice then uses the practice side of the system to review, organise and process that data.

The aim is that the client can see useful business information, reports and VAT work without having to understand accounting software in detail.

What HMRC Needed To Know

HMRC asks software providers to confirm that the software is built and operated responsibly before production credentials are issued.

In simple terms, HMRC wanted to know:

- Who is responsible for the software.
- Whether the software is marketed honestly.
- Whether the software is developed and tested properly.
- Whether customers can report problems or security concerns.
- Whether customer data is protected.
- Whether the software has been security checked.
- Whether HMRC fraud-prevention information is sent with API requests.
- Whether customers understand what they are authorising.

What We Completed

We completed the HMRC Developer Hub checklist and submitted the production credentials request.

HMRC then showed the message:

`We have received your request for production credentials`.

Organisation Information

The request was made for the software provider, not for every future client.

The UTR used identifies the provider organisation. When future clients use the SaaS product, they will authorise their own HMRC account through HMRC's authorisation process. Their HMRC login details are not stored in LedgerHouse.

Customer Privacy And Terms

HMRC asked for public pages explaining privacy and terms.

We added:

- Privacy page: `https://ledgerhouse.finaccord.pro/privacy/`
- Terms page: `https://ledgerhouse.finaccord.pro/terms/`

These pages are available without needing to log in, so HMRC and customers can view them.

Before taking paying public clients, the wording should still be reviewed as formal legal documents.

Customer Data Protection

We improved and tested how the system protects customer data.

The important points are:

- Users must log in to see protected areas.
- Client users can only see companies assigned to them.
- Client users cannot open the practice workbench.
- Practice/HMRC/Companies House work areas are restricted to staff users.
- HMRC access is handled through OAuth authorisation.
- LedgerHouse does not store customer HMRC passwords.
- HMRC tokens and bank consent tokens are encrypted in the database.
- Customers can export their data if they switch provider.

Fraud-Prevention Information

HMRC requires software to send fraud-prevention information when calling certain HMRC APIs.

We added the required web-app-via-server fraud-prevention headers. These include information such as connection method, browser details, device ID, screen details, timezone and vendor details.

We tested the generated headers using HMRC's own sandbox validator. HMRC returned:

`VALID_HEADERS`

That means HMRC's test service accepted the fraud-prevention header set for the connection method.

Security Work

We added or confirmed security controls including:

- Encrypted storage for sensitive tokens.
- Security headers on web responses.
- Content Security Policy.
- HTTP-only CSRF cookie.
- Staff-only access to sensitive workbenches.
- Tenant restrictions so one client's data is not shown to another client.
- Tests checking that unauthorised users are blocked.

We also ran an OWASP ZAP baseline security scan against the local app.

Result:

- No new failing security findings.
- 60 checks passed.
- Remaining warnings were documented and explained.

Accessibility Work

We checked the key user screens for accessibility:

- Login.
- Client portal.
- Practice dashboard.
- HMRC VAT workspace.
- Client VAT review.

We improved labels, keyboard access, focus styling and colour contrast. Automated accessibility checks recorded no issues on the key screens covered.

Testing Work

The app was tested locally using Docker and PostgreSQL.

The latest full automated test run passed:

```
103 tests OK
```

Those tests covered areas such as:

- Login.
- Client upload flows.
- Client portal.
- Practice workbench.
- Bank file processing.
- PDF/evidence upload.
- Accounting calculations.
- VAT workflow.
- HMRC OAuth and VAT API preparation.

- Fraud-prevention headers.
- Token encryption.
- Tenant/client separation.
- Report exports.
- Companies House integration scaffolding.

Why We Could Submit The HMRC Request

The request was submitted because the required HMRC checklist areas had evidence behind them:

- The organisation was identified.
- Marketing answers were straightforward because the product is not using HMRC branding or advertising.
- Development and testing evidence existed.
- Customer support and incident process existed.
- Customer data controls were added and tested.
- Security checks were completed and documented.
- Fraud-prevention headers were implemented and accepted by HMRC's sandbox validator.
- Privacy and terms URLs were added.
- The full local test suite passed.

What This Does Not Mean Yet

This does not mean the whole SaaS product is finished for public paid launch.

It means the HMRC production credentials request has been submitted and the local evidence supports the answers used.

Before external paying clients are onboarded, the remaining important work is:

- Wait for HMRC to approve production credentials.
- Deploy to the final production environment when ready.
- Set real production secrets and encryption keys.
- Confirm HTTPS is working on the public domain.
- Review the privacy notice and terms legally.
- Run final checks against the live production site.
- Confirm backups and recovery.

Simple Conclusion

We did not just tick boxes blindly. We added missing controls, created public policy pages, implemented HMRC fraud-prevention headers, encrypted sensitive tokens, restricted client access, tested the application, recorded the evidence and then submitted the HMRC production credentials request.

The request is now with HMRC.